

Fraud360

Fraud Risk Management & Early Warning Signals Platform

A multi-tenant, RBI-aligned FRMS with real-time transaction monitoring, an enforced Red Flagged Account lifecycle, and regulatory reporting — delivered as a shared service to commercial banks, co-operative banks and NBFCs.

DOCUMENT	VERSION	DATE	STATUS	COMPANION
BRD / FRMS-EWS	1.10	2 October 2026	For review	HLD v1.9

CONTENTS

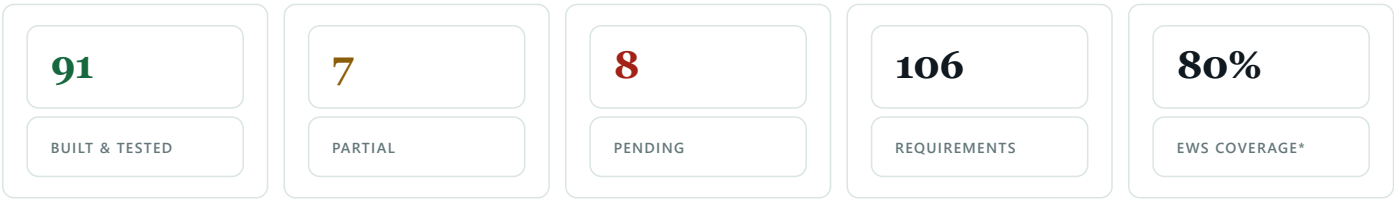
1	Purpose & scope	11	Requirements — access & privacy
2	Market & business case	12	Requirements — model governance
3	Regulatory basis	13	Requirements — platform ops
4	Stakeholders & personas	14	Non-functional
5	Requirements — tenancy	15	Obligation traceability
6	Requirements — ingestion	16	Assumptions & exclusions
7	Requirements — detection	17	Release plan
8	Requirements — RFA lifecycle	18	What still blocks a commercial release
9	Requirements — reporting	19	Open decisions
10	Requirements — analytics	20	AI/ML roadmap

1. Purpose and scope

What this document commits the product to, and the boundary of the first commercial release.

This BRD states the business requirements for a commercially licensed Fraud Risk Management System (FRMS) incorporating an Early Warning Signal (EWS) framework, built to the RBI Master Directions on Fraud Risk Management and the supervisory expectations that surround them. The platform was originally built against the three combined Directions issued 15 July 2024; RBI withdrew those on 31 July 2026 and replaced them with nine entity-specific Directions (RBI/DoS/2026-27/412–463) — see REG-01. The requirements below reflect the 2026 structure.

The platform is **multi-tenant by design**. One deployment serves many regulated entities, each with its own branding, its own board-approved thresholds, its own data and its own users. This is a deliberate commercial position: the compliance machinery an EWS framework requires is largely identical across institutions, while the thresholds and governance around it are emphatically not.



*Coverage of *our own* 33 indicators, which is a narrower claim than coverage of RBI's illustrative list — see the note below. 28 of 33 quantitative indicators are measurable once a tenant sends its feeds: 13 from the payment stream alone, CPT-02, CPT-03 and CPT-04 from screening lists, and BEH-02, BEH-03 and CBS-01 through CBS-10 from the core-banking event intake. The remaining five need records the platform cannot yet take — invoice lines, session geolocation and trade-finance documents — and are reported as unmeasurable *with the reason*, never scored as zero. See section 7.

On the RBI early-warning-signal list. The 2016 Master Directions on Frauds carried an illustrative annexure of **42** early-warning signals (widely reported as 45). The **2024** Master Directions on Fraud Risk Management (RBI/DOS/2024-25/118, 15 July 2024) **supersede** the 2016 Directions and **enumerate no list at all** — they require each bank's board-approved policy to define its own signals, attach EWS/RFA at the CRILC threshold of **₹3 crore**, and examine an alert within **30 days**. RBI withdrew the 2024 Directions in turn on 31 July 2026, splitting them into nine entity-specific instruments (RBI/DoS/2026-27/412–463) that share the same chapter backbone and the same no-enumerated-list, board-owns-its-own-signals design this note describes — see REG-01. The specific rupee and day figures above are stated as this platform's own configured defaults (see policy.py's threshold model per entity type) and must be confirmed against each entity type's own 2026 Direction text before being relied on as an exact regulatory figure.

Mapped against the 2016 annexure, the platform fully covers **40 of 42** signals, partially covers **2**, and leaves **0** uncovered — every one of the 42 now maps to at least a partial indicator, and all but two map to a full one. Two catalogues share that coverage. Account-conduct signals that arrive as events — cheque returns, BG invocation and LC devolvement, interest funded by a fresh sanction, delayed repayment, diversion, cash withdrawal — are payment-rail and core-banking rules (CBS-01 through CBS-10 among them). A verified title-dispute register (CPT-04) and a verified related-party register (CBS-09/10) closed the last gaps in that catalogue this round, replacing the proxies (CPT-03's multiple-charge detection, CBS-01/03's group-exposure ratio) that previously stood in for them. The borrower-conduct and credit-monitoring signals — audited financials, stock-audit findings, ROC filings, auditor's reports — are read from a loan file on a periodic cycle, not from a payment stream in real time, by Lane C's own catalogue, **LNC-01 through LNC-23**. Several Lane C signals are built but unmeasurable until a tenant configures the matching reference feed, a credit officer records a finding, or a borrower's project-appraisal baseline and progress submission are both on file — reported as unmeasurable, never scored as zero. LNC-02 (project scope change, #3) also counts how many times a borrower's reported completion date has actually changed across every period on file, directly answering RBI's own word "frequent" rather than checking only the current period's own slip. LNC-11 (a negative rating action) has no counterpart on the list and is never counted toward the 42. The two

remaining partial covers are both the same off-by-default local-LLM read of the annual report (#38, #39) — deliberately never promoted to "full": a probabilistic read should not claim to be deterministic. Conversely **20 of our 36** indicators have no counterpart on that list, because they are payment-fraud typologies answering a different question. The mapping is generated and kept current by `docs/rbi_ews_mapping.py`.

IN SCOPE

- Transaction ingestion across UPI, IMPS, NEFT, RTGS and card rails
- **Inline decisioning (Lane A)** — a go/no-go answer inside the payment window for rails a tenant configures for it, alongside the existing queue-drained detection lane. Shipped in *shadow* mode: every decision is computed, recorded and reportable, and the enforced answer stays `allow` until a tenant turns enforcement on. See BR-312 to BR-315
- Rule-based EWS detection driven by each entity's configured catalogue
- Alert triage, case management and the full RFA lifecycle including natural justice
- Regulatory reporting to RBI (FMR) and FIU-IND (STR/CTR)
- Board, supervisory, investigative and inspection-facing analytics
- Tenant onboarding, branding, configuration and user administration

EXPLICITLY OUT OF SCOPE FOR RELEASE 1

- KYC/CKYC onboarding, AML customer risk rating and sanctions screening as primary systems — the platform consumes these as feeds
- Cheque truncation, trade finance document examination and loan origination
- Recovery, legal case management and LEA case tracking beyond referral records

2. Market and business case

Why a shared platform, and who buys it.

The July 2024 Directions extended a materially uniform fraud-governance obligation across three very different populations of regulated entity. A large commercial bank can fund a bespoke FRMS. A Tier-1 urban co-operative bank, a state co-operative bank or a mid-size NBFC carries the same obligations — board-approved policy, EWS framework, RFA classification, natural justice, FMR reporting — against a fraction of the technology budget. That asymmetry is the market.

SEGMENT	GOVERNING INSTRUMENT	SUPERVISOR	COMMERCIAL POSITION
Commercial banks	MD on Fraud Risk Management in Commercial Banks, 2026 (RBI/DoS/2026-27/412)	RBI	Displace or augment an incumbent FRMS; strongest on EWS coverage evidence and reconciliation
Regional Rural Banks	MD on Fraud Risk Management in Regional Rural Banks, 2026 (RBI/DoS/2026-27/454) — no longer bundled with Commercial Banks	RBI, NABARD	Same commercial position as Commercial Banks, smaller scale
All India Financial Institutions	MD on Fraud Risk Management in AIFIs, 2026 (RBI/DoS/2026-27/457) — now its own instrument, not bundled with Commercial Banks	RBI	Small, named population (EXIM, NABARD, NHB, SIDBI, NaBFID) — not a volume segment
Urban co-operative banks (Tiers 1–4)	MD on Fraud Risk Management in Urban Co-operative Banks, 2026 (RBI/DoS/2026-27/439)	RBI	Primary target. Obligation without budget; tiered thresholds are a product feature
State & central co-operative banks	MD on Fraud Risk Management in Rural Co-operative Banks, 2026 (RBI/DoS/2026-27/451) — UCB and rural co-operative banks are separate 2026 instruments, no longer one combined Direction	NABARD	Same as UCB, with NABARD reporting lines
Local Area Banks	MD on Fraud Risk Management in Local Area Banks, 2026 (RBI/DoS/2026-27/446)	RBI	Smallest, most geographically restricted licence class; not previously modelled as its own entity type
Small Finance Banks	MD on Fraud Risk Management in Small Finance Banks, 2026 (RBI/DoS/2026-27/421)	RBI	Full lending licence at smaller scale; not previously modelled as its own entity type
Payments Banks	MD on Fraud Risk Management in Payments Banks, 2026 (RBI/DoS/2026-27/430)	RBI	Cannot extend credit — credit-linked EWS rule families do not apply; not previously modelled as its own entity type
NBFCs and HFCs	MD on Fraud Risk Management in NBFCs (incl. HFCs), 2026 (RBI/DoS/2026-27/463)	RBI / NHB for HFCs	Growing enforcement attention; lighter transaction volume, same lifecycle burden

CENTRAL PRODUCT CLAIM

Every figure the platform reports is derived from a single metric definition and is proven to reconcile at query time. A board pack, a supervisory return and an analyst's screen cannot disagree, because they are the same SQL. This is the differentiator against dashboards assembled from independent queries, and it is verifiable rather than asserted.

3. Regulatory basis

The instruments that generate the obligations traced in section 15.

REF	INSTRUMENT	BEARING ON THE PLATFORM
REG-01	RBI Master Directions on Fraud Risk Management, 31 Jul 2026 (RBI/DoS/2026-27/412–463, nine entity-specific instruments — withdrew and replaced the three combined 15 Jul 2024 Directions this platform was originally built against)	Board-approved fraud risk policy; EWS framework; RFA classification; staff accountability; FMR reporting; governance committee structure
REG-02	<i>State Bank of India v. Rajesh Agarwal</i> (SC, 2023)	A borrower must be given a hearing and a reasoned order before being classified as fraudulent. Procedural, not advisory
REG-03	Prevention of Money Laundering Act and FIU-IND reporting rules	STR and CTR obligations; principal officer role; filing timelines
REG-04	RBI FREE-AI Committee report, Aug 2025	Model governance, explainability, human oversight, model inventory and drift monitoring where AI/ML is used
REG-05	Digital Personal Data Protection Act, 2023	Purpose limitation, data minimisation, retention limits, processor obligations
REG-06	RBI MD on Outsourcing of IT Services, Apr 2023	Directly governs this platform as a service provider: right to audit, exit, concentration risk, sub-contracting, data localisation
REG-07	RBI storage of payment system data directive, Apr 2018	Payment data to be stored within India
REG-08	RBI MD on IT Governance, Risk, Controls and Assurance Practices, Nov 2023	Change management, access control, audit logging, BCP/DR

THRESHOLD VALUES ARE THE ENTITY'S, NEVER THE VENDOR'S

Response windows, filing deadlines, materiality limits and severity bands differ by entity type and tier, and each must be the figure that entity's own board approved. The platform ships documented defaults so a new tenant is never unconfigured, and treats every one of them as a value the tenant must review and own. No number in this document should be read as regulatory advice.

4. Stakeholders and personas

Eleven roles, each with a different question and a different permitted view of the same data.

PERSONA	PRIMARY QUESTION	MAY UNMASK CUSTOMER PII
Fraud Analyst (L1)	Which alerts in my queue are real?	Yes, with justification
Senior Investigator (L2)	What is the full picture behind this case?	Yes, with justification
Fraud Risk Manager	Are we within SLA and correctly staffed?	Yes, with justification
Principal Officer (PMLA)	What must be filed with FIU-IND, and by when?	Yes, with justification
Compliance Supervisor	Are the regulatory clocks being met?	Yes, with justification
Board / Executive	What is our fraud exposure and trend?	No — aggregate only
CRO / ACB / Special Committee	Is the framework itself working?	No — aggregate only
Model Risk / Data Science	Is detection still fit for the population?	No — models run on masked data
Internal Audit / RBI Inspection	Can each figure and decision be evidenced?	Read-only, with justification
Tenant Administrator	Is my institution configured correctly?	Yes, with justification
Platform Administrator (vendor)	Is the service healthy across tenants?	No — see below

THE OUTSOURCING BOUNDARY

Vendor staff cannot unmask a bank's customer identifiers under any role. Operating the service does not require seeing the customers, and REG-06 makes this the first question an outsourcing review asks. It is enforced in the permission model and in the database grants, not by policy alone.

5. Requirements — tenancy, onboarding and configuration

BR-1xx. Making one platform serve many regulated entities, each governed by its own board.

ID	REQUIREMENT	PRIORITY	STATUS
BR-101	Onboard a regulated entity with slug, legal name, entity type and, for UCBs, supervisory tier	MUST	BUILT
BR-102	Apply tenant branding — display name, logo, primary/accent/neutral colours, default theme, custom domain	MUST	BUILT
BR-103	Derive the tenant's default FRM policy from entity type and tier, including governing Direction and reporting lines (RBI / NABARD / NHB / FIU-IND)	MUST	BUILT
BR-104	Allow a tenant administrator to review and override every policy threshold, recording that it is board-approved	MUST	BUILT
BR-105	Version every configuration change; activate one version at a time; retain superseded versions	MUST	BUILT
BR-106	Provide a structured rule editor so thresholds can be retuned without editing JSON	SHOULD	BUILT
BR-107	Suspend, resume and offboard a tenant, with a complete data export on exit (REG-06)	MUST	BUILT
BR-108	Invite tenant users with a role, a temporary password and forced reset at first login. Found and fixed this cycle: create and delete were <code>require_role("platform_admin")</code> only — a bank's own tenant_admin could view their user list but not invite, update or remove anyone; every one of those required the vendor's own staff to act on the bank's behalf, undocumented as an actor mismatch until this session's FSD sweep named it. Fixed: create, update (new — role reassignment, previously not possible for any actor at all) and delete are now gated by <code>can_admin_tenant</code> , checked dynamically so a BR-113 custom role granted admin scope gets the same reach as the seeded <code>tenant_admin</code> . A safety net added alongside: removing or demoting a user is refused if it would leave the tenant with nobody able to administer it, not merely if it would leave zero users — the latter is what the code checked before and would have allowed a tenant with several users but zero admin-capable ones. Since BR-113 phase 2e the role a user holds is always one of the tenant's own role rows, and the invite form offers exactly those: a role an administrator deletes can no longer be assigned	MUST	BUILT
BR-109	Self-service tenant onboarding and an isolated sandbox tenant for integration testing. Built as <code>POST /tenants/self-service</code> — unauthenticated (the one path the gateway admits under the <code>tenants</code> segment without a bearer token), running the same onboarding orchestration <code>platform_admin</code> 's <code>POST /tenants</code> always has, but always producing a tenant with <code>is_sandbox=true</code> . Isolation is enforced, not just labelled: <code>/ingest/{tenant_id}/transactions</code> and <code>/cbs-events</code> refuse a sandbox tenant's batch outright if it claims <code>source="live"</code> , so sandbox traffic can never be miscounted as the traffic BR-508 (CTR) or BR-611 build regulatory filings and live/demo reporting from. One live sandbox per admin email (a signup guard, not a login wall). A console form on the login page (no sign-in required) drives it end-to-end. Promotion to a real, billable tenant is a separate, deliberate <code>platform_admin</code> action (<code>POST /tenants/{id}/promote</code>) — never automatic, never self-service.	SHOULD	BUILT
BR-110	Meter usage per tenant for billing (transactions ingested, alerts scored, seats)	SHOULD	BUILT
BR-111	Gate the seeded EWS rule catalogue by entity-type capability — a licence that cannot extend credit (Payments Bank) does not get the 20 credit-linked rules (loan-account misuse, borrowal-account conduct, collateral, title disputes, related-party exposure, qualitative credit signals, loan origination) seeded at onboarding	MUST	BUILT
BR-112	Phase 1 of role flexibility: give a tenant administrator a read-only view of the platform's role catalogue — what each of the tenant's own roles can access (modules, dashboards, gated actions, PII-reveal, admin scope) — and which of their own users currently hold each one. It began as pure transparency over a catalogue held in code; since BR-113 phase 2e the roles are the tenant's own database rows and this view lists them, with their permissions and descriptions. Establishes, from real tenant usage, whether the fixed set actually needs extending before Phase 2 is built. <code>GET /tenants/{id}/roles</code> — same access level as the existing user list (any authenticated user of the tenant, not admin-only), scoped to the tenant's own roles; <code>platform_admin</code> never appears, matching the floor BR-108's invite flow already enforces	SHOULD	BUILT

ID	REQUIREMENT	PRIORITY	STATUS
BR-113	Phase 2 of role flexibility: let a tenant define its own roles and permission grants — custom module/dashboard access, PII-reveal and admin scope — beyond the fixed ten-role catalogue, with the same versioning, maker-checker and audit trail every other tenant configuration carries, and without a tenant-defined role ever able to reach cross-tenant scope or the platform-staff PII floor. Not a functional or regulatory gap today: RBAC, least-privilege and segregation of duties are already satisfied by the fixed catalogue, and every seeded role maps to a named persona the FRM Directions themselves expect (Principal Officer, ACB/CRO, board). Phase 2a (persistence) is built: every tenant gets its own materialised <code>tenant_roles</code> rows, seeded at onboarding the same way BR-111 seeds the EWS rule catalogue, verified byte-for-byte equivalent to the pre-existing hardcoded catalogue against a frozen backup (<code>scripts/backups/rbac_py_pre_br113_20260816.py</code>). Phase 2b (write path, guardrails, versioning, capability) is built: a tenant with <code>can_admin_tenant</code> — checked dynamically, so a custom role granting it can manage roles too, not only the seeded <code>tenant_admin</code> — can create, edit and delete a role via <code>POST / PUT / DELETE /tenants/{id}/roles</code>. Guardrails refuse a tenant role reaching the platform-only <code>administration</code> module or the <code>tenant_health</code> dashboard, and refuse shadowing a reserved platform name; cross-tenant reach is structurally impossible since <code>tenant_id</code> is never client-supplied. Raising <code>can_admin_tenant</code> / <code>can_reveal_pii</code> is staged and needs a <i>different</i> eligible person to confirm (<code>POST ... /confirm</code>, <code>self_approval</code> refused) — the same maker-checker asymmetry BR-715 applies elsewhere: lowering a privilege applies immediately, raising one does not. Every create/edit writes a full before/after snapshot to the audit trail rather than mutating history in place, so “what could this role do on date X” stays answerable without a separate version table. A custom role is assignable through BR-108’s invite flow the moment it exists. A minimal console screen (list, create, delete, with the invite form’s role picker now reading the tenant’s real catalogue instead of a hardcoded list) ships with it. Phase 2c (cross-service capability) is built: analytics-service, config-service, decision-service and notification-service now consult a tenant’s custom roles too, via <code>cp_common.dynamic_roles</code> — a shared module every one of them imports, so the fetch-and-cache logic against tenant-service’s new internal endpoint (<code>GET /tenants/internal/{tenant_id}/roles</code>) is written once, not five times. Every one of the ten fixed roles resolves with zero network calls, exactly as before — only a name outside that set triggers a lookup, cached against the same generation-token mechanism config-service’s rule/policy changes already use, so a role edit is visible to every service the instant tenant-service bumps it, not after a clock interval. This covers the four generic capability primitives — module access, dashboard access, <code>can_admin_tenant</code>, <code>can_reveal_pii</code> — which is what every dashboard gate, every “or admin” fallback, and config-service’s maker-checker eligibility across all four services actually run on. <code>ingestion-service</code> needed no change: it has no human role checks at all, only machine-credential scopes (BR-213). Verified against real HTTP round trips between services, not only in-process function calls, including a caught-and-fixed bug (the internal endpoint’s URL was missing its router prefix) that a narrower test would have missed. Phase 2d (risk_manager-equivalent capability) is built: <code>TenantRole</code> gained a third flag, <code>can_activate_config</code> — may propose or confirm a configuration activation (BR-715), independent of <code>can_admin_tenant</code>. config-service’s <code>maker_checker.ensure_eligible()</code> now checks this one flag dynamically instead of a hardcoded name list; <code>tenant_admin</code> and <code>platform_admin</code> carry it alongside full admin scope, <code>risk_manager</code> carries it on its own — exactly the distinction its own name always implied but the code never expressed as a setttable grant. A custom role can now be given that narrower capability without also becoming a tenant administrator, or vice versa: administering a tenant (users, branding, other roles) no longer implies the power to activate fraud-detection configuration, and the two are verified independent of each other. Raising the flag is staged through the same maker-checker elevation as the other two — a different eligible person must confirm — and it is visible in the console’s role table and create-role form alongside Admin and PII. A tenant-defined role is otherwise fully functional platform-wide: created via BR-113’s write path, assignable to a user via BR-108, and recognised for module/dashboard access and all three capability flags in every service that gates on them. That remaining gap is closed by phase 2e, below. Phase 2e (roles are data) is built: nothing that decides what a person may do is held in code. The ten starter roles are templates copied into a tenant’s own rows at onboarding (and, for existing tenants, by data migration); after that they are ordinary rows that an administrator can edit, narrow, widen or delete, and that a platform administrator can change for any tenant. Every service decides from those rows alone — there is no in-code catalogue to fall back on and no list of role names anywhere. A role name that is not a row can do nothing, and a service that cannot read a tenant’s roles refuses rather than guesses. A role now carries, beyond its modules, dashboards and three capability flags, a set of permissions (BR-114) and a description shown to its holders on their home page (BR-116). The implicit “a tenant administrator may do anything” override is removed: an administrator holds each permission explicitly. The guard-rails that remain protect a tenant from itself: privilege-raising edits (a capability flag or a permission) are staged for a second person; an edit or delete that would leave the tenant with no administrator who can sign in is refused; a role still held by a user cannot be deleted; unknown permissions, the platform-only module and Tenant Health are refused. Only the platform operator (<code>platform_admin</code>, Finverge staff) is recognised by name in code — it is not a bank’s role and no tenant can edit it. Verified through the live console by signing in as each of the ten roles.	SHOULD	BUILT
BR-114	Gated actions are permissions held by roles. Every action the platform can gate — each case-workflow step, the staff-accountability examination and its conclusion, recoveries and agency referrals, detection simulate and replay, loading reference lists, FMR/STR and CTR filing, board packs, usage view, machine credentials, sanctions screening and borrower credit health — is a named permission granted per role in the tenant’s own rows and changed from the console; no endpoint decides by role name. 28 permissions today. The starter grants reproduce the previous behaviour exactly, so nothing changes for a tenant until its administrator edits a role. <code>GET /tenants/{id}/permissions</code> serves the vocabulary the role editor offers; each case-workflow action has its own permission and a test keeps the two lists identical. Raising a permission is a privilege-raising edit (staged, second person), lowering one applies on the next request	MUST	BUILT
BR-115	Sanctions screening and borrower credit health are permission-gated and enforced by the servers: <code>sanctions.screen</code> , <code>lane_c.view</code> (scores, signals, alerts) and <code>lane_c.manage</code> (upload, review, manual findings, project appraisal and progress). Found and fixed this cycle: those endpoints checked only the tenant, so any signed-in user — a Board member, a data scientist — could read borrower-level credit data and run sanctions screens. Starter grants: Board, CRO and Model Risk hold none; Analyst, Investigator, Supervisor and RBI Inspector can look but not change; Risk Manager, Principal Officer and Tenant Administrator can do both. The console hides pages a role cannot use. A test fails if a Lane C endpoint is added without the check	MUST	BUILT
BR-116	A home page built from what the person’s own role may open. Every user lands on Home: a banner with their role’s description and scope (their bank; whether customer identifiers can be unmasked), the work waiting for them (alert, case, regulatory-clock and filing queues) in areas their role can open, headline figures from their home dashboard (the first in the role’s list, so an administrator chooses it by ordering), and the pages open to them. A platform administrator sees the platform’s tenants and their state instead. Nothing is shown that the person cannot click through to; the menu and Monitoring tabs follow the same rule	SHOULD	BUILT

6. Requirements — transaction ingestion

BR-2xx. Getting real payments into the platform without corrupting them on the way in.

ID	REQUIREMENT	PRIORITY	STATUS
BR-201	Accept transactions over an authenticated API in native rail formats for UPI, IMPS, NEFT, RTGS and card	MUST	BUILT
BR-202	Map each rail to one canonical transaction shape at the edge, so detection is rail-agnostic	MUST	BUILT
BR-213	Authenticate bank systems (payment switch, CBS extract, ETL) with a machine credential that has no interactive login path, a scope that cannot reach customer data, optional certificate binding, an address allow-list and enforced expiry — rather than a user account with MFA disabled	MUST	BUILT
BR-203	Represent money as integer paise end to end; reject amounts finer than one paisa rather than rounding	MUST	BUILT
BR-204	Reject timestamps without a timezone offset, with an explanatory error	MUST	BUILT
BR-205	Deduplicate on the rail's own identifier so a replayed file does not double-count value	MUST	BUILT
BR-206	Accept a batch partially: report each rejected row with its index and reason, and retain the rest	MUST	BUILT
BR-207	Retain the inbound payload immutably, separate from derived facts, with the time of receipt	MUST	BUILT
BR-208	Expose queue depth, provenance and freshness for operational monitoring	MUST	BUILT
BR-209	Accept bulk files over SFTP in CSV and ISO 20022, with the same validation contract	MUST	BUILT
BR-210	Support historical backfill and controlled replay after a rule change, without duplicating alerts	MUST	BUILT
BR-211	Ingest non-payment signals — CBS account events, loan account conduct, RM-raised qualitative indicators	MUST	BUILT
BR-212	Consume reference feeds: sanctions and negative lists, CERSAI charge registry, device/session telemetry	MUST	BUILT
BR-214	Ingest loan-origination (LOS) / underwriting-stage signals — falsified applications, straw borrowers, collusive valuations — not only post-disbursement CBS loan conduct. ~92% of FY25 reported bank fraud value is loan/advances fraud (RBI Annual Report FY25). Two new CBS event kinds (<code>loan_application</code> , <code>collateral_valuation</code>) and a new LOS rule family (LOS-01 declared income vs. observed activity, LOS-02 valuation vs. peer benchmark, LOS-03 identity reused across applications), evaluated in their own pass since an application has no payment transaction to piggyback scoring on — see FSD §“Detection scope”	SHOULD	BUILT

7. Requirements — EWS detection

BR-3xx. The indicator framework itself, and the rule that the entity's own configuration governs it.

ID	REQUIREMENT	PRIORITY	STATUS
BR-301	Maintain an EWS indicator catalogue across ten families: velocity, structuring, behavioural, layering/mule, counterparty, channel/device, trade-based, loan-account misuse, qualitative, loan origination (BR-214)	MUST	BUILT
BR-302	Detection must read thresholds from the entity's active configuration, so retuning a band in the console changes what fires with no code change	MUST	BUILT
BR-303	A badly-tuned threshold must genuinely miss fraud — no indicator may be force-fired to populate a screen	MUST	BUILT
BR-304	Record on every alert the band matched, the observed value, the threshold applied, the unit, and the configuration version in force at scoring time	MUST	BUILT
BR-305	Score both the paying and the receiving account, so a collection account that only receives is still assessed	MUST	BUILT
BR-306	Report indicators that cannot be measured for want of a data feed, with the reason, and never approximate them	MUST	BUILT
BR-307	Maintain a dormant-indicator register: configured indicators that produced no signal in the period	MUST	BUILT
BR-308	Group related alerts into one case by account so a mule ring is one investigation, not forty alerts	MUST	BUILT
BR-309	Detect within seconds of receipt, sustained, at each tenant's peak transaction rate	MUST	BUILT
BR-310	Support network/graph typologies requiring multi-hop traversal (circular flow, layered chains)	MUST	BUILT
BR-311	Allow an authorised user to simulate a threshold change against historical data before activating it	SHOULD	BUILT
BR-312	Return a go/no-go decision (allow, challenge, hold, decline) inside the payment window, on a per-rail latency budget set by the tenant	MUST	BUILT

ID	REQUIREMENT	PRIORITY	STATUS
BR-313	Run inline decisioning in shadow mode first — compute and record the decision that <i>would</i> have been taken while returning allow, so a tenant can measure the effect before enforcing it	MUST	BUILT
BR-314	Route each rail to the inline lane or the near-real-time lane by tenant configuration, and refuse a request for a rail configured for the other lane rather than answering allow	MUST	BUILT
BR-315	When the latency budget expires mid-evaluation, report which rules were skipped and record the outcome as budget-exceeded — never as a clean pass	MUST	BUILT
BR-316	Define and record graduation criteria and an approval trail — minimum shadow-mode duration, observed false-positive rate, and board/ACB sign-off — before a rail moves from shadow to enforced. Closes the narrower question OD-03 left open: not <i>whether</i> to enforce, but what a tenant must observe and who must approve before it does. Built as a gate on a new <code>decision_policy</code> config kind: any rail a version marks enforced needs its own graduation record (≥30 days observed, false-positive rate, board/ACB approval) before the version may even be proposed for activation — same maker-checker and board-attestation mechanisms as BR-715/BR-104, applied per rail. This also closed a bigger gap it surfaced: <code>decision_policy</code> was never actually wired to config-service before — every tenant ran the hardcoded starter policy permanently, with no path to change it	SHOULD	BUILT
BR-317	Accept ISO 8583 authorisation messages from a card/EFT switch that has no practical way to originate JSON, translated onto the same inline decision contract as BR-312 rather than asking every such vendor to build their own translation layer. Built as a new <code>iso8583_gateway</code> component: a TCP listener that decodes the standard public data elements (DE2/3/4/7/11/32/37/39/41/42/49), maps them to a <code>/decide</code> request, and calls it exactly as any JSON Lane A integrator would — same rule catalogue, same policy, same decision log, one brain behind two front doors. Core codec, field mapper and connection handling are built and unit-tested (45 tests: message round-trip, DE7's year-less date resolved against an explicit configured offset, PAN masked at the point it first arrives and never logged or persisted raw, and every failure path — malformed message, unreachable <code>/decide</code> , an unrecognised <code>/decide</code> response — produces an explicit refusal rather than a guessed approval). Not yet deployed for any tenant. Every switch vendor's private-field usage and exact response-code table differs (DE48/62/120-127), so the field mapping here covers only the standard 1987 data elements until a pilot vendor's own spec is confirmed against it; whether Fraud360 terminating raw PAN brings it into PCI-DSS cardholder-data scope is a compliance decision still pending, not an engineering one. See <code>docs/ISO8583_LANE_A_SCOPING.md</code>	SHOULD	PARTIAL

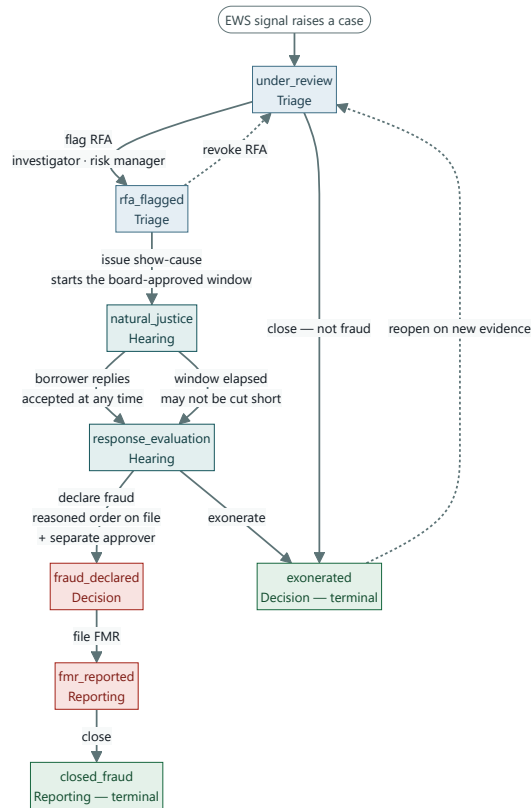
CURRENT COVERAGE, STATED PLAINLY

Eleven indicators are computed from the payment stream today, giving 96% coverage of the configured quantitative catalogue in the reference tenant. Eight further indicators are inert pending the feeds in BR-211 and BR-212 and are reported as such. Coverage should be quoted to prospects with that qualification attached, not as a headline percentage.

8. Requirements — alert triage and the RFA lifecycle

BR-4xx. What happens after an indicator trips — the part the Directions are mostly

about.



The RFA lifecycle as enforced. The spine runs top to bottom through the four stages — triage, hearing, decision, reporting — shaded by stage. Solid edges advance a case; dotted edges are the two permitted reversals. Every transition is gated by role, required evidence and elapsed time. `closed_fraud` is terminal and cannot be reopened: it has been reported to the regulator.

ID	REQUIREMENT	PRIORITY	STATUS
BR-401	Case state may change only through the defined lifecycle; no other path may write it	MUST	BUILT
BR-402	Each transition is permitted only to specified roles	MUST	BUILT
BR-403	Issuing a show-cause notice starts the borrower's response window at the entity's board-approved length	MUST	BUILT
BR-404	The response window may not be cut short by any user at any seniority (REG-02)	MUST	BUILT
BR-405	A borrower's reply may be recorded at any time and moves the case forward	MUST	BUILT
BR-406	Fraud may not be declared without a reasoned order attached to the case (REG-02)	MUST	BUILT
BR-407	Declaring fraud requires a maker and a separate checker; self-approval is refused	MUST	BUILT
BR-408	An action taken outside its policy window is permitted but permanently recorded as a breach	MUST	BUILT
BR-409	Every attempt, including refused ones, is written to an append-only case history	MUST	BUILT
BR-410	Unavailable actions are shown disabled with the reason, never hidden	SHOULD	BUILT
BR-411	Cases may be assigned to a named investigator; assignment is audited	MUST	BUILT
BR-412	Attach evidence documents to a case with a content hash; documents cannot be deleted	MUST	BUILT
BR-413	Notify the assignee, and escalate on approaching or breached clocks, by email and in-app	MUST	BUILT
BR-414	Record staff accountability examination outcomes against a declared fraud (REG-01)	MUST	BUILT
BR-415	Record LEA referral and recovery progress against a closed fraud	SHOULD	BUILT

9. Requirements — regulatory reporting

BR-5xx. The filings the lifecycle exists to produce.

ID	REQUIREMENT	PRIORITY	STATUS
BR-501	Track FMR and STR due dates from the decision date, using the entity's configured filing windows	MUST	BUILT
BR-502	Classify every fraud against an FMR category	MUST	BUILT
BR-503	Report filings due, filed and overdue, per period, reconciled to case detail	MUST	BUILT
BR-504	Generate the FMR submission artefact in the prescribed format, ready for upload	MUST	PARTIAL
BR-505	Generate the STR artefact for FIU-IND in the prescribed format	MUST	PARTIAL
BR-506	Retain every submitted artefact with its generation timestamp and the data version behind it	MUST	BUILT
BR-507	Produce a board / ACB pack on a schedule, distributed to named recipients	MUST	BUILT
BR-508	Support CTR aggregation and threshold reporting. PMLA Rule 3: cash transactions, deposits and withdrawals both, aggregated per account per calendar month against a Rs 10,00,000 threshold — individually or in connected smaller transactions. Cash does not traverse UPI/NEFT/RTGS/CARD, so a new <code>cash_transaction</code> CBS event kind carries it in on BR-211's existing intake path; account-and-month centric, not case-centric, so it is its own filing lifecycle (generate/download/acknowledge) rather than a variant of the FMR/STR one	SHOULD	BUILT
BR-509	Screen against RBI's Central Fraud Registry (CFR). Verified against the Directions' own text (Chapter VI-B, para 47): CFR is <i>not</i> a second return a bank files — it is populated automatically from FMR submissions (already built), and the bank's obligation is to <i>use</i> CFR data for credit/fraud risk decisions. Access is per-user RBI portal credentials, not a bulk feed the way sanctions lists are published, so CFR is now a reference-data source (feeding CPT-02 alongside sanctions/PEP/negative-list) that a tenant's compliance team loads from its own portal lookups — honestly unloaded, not silently clean, until then	SHOULD	BUILT

10. Requirements — analytics and assurance

BR-6xx. Thirteen role-scoped dashboards over one metric definition.

ID	REQUIREMENT	PRIORITY	STATUS
BR-601	Define every metric exactly once; all dashboards read that definition	MUST	BUILT
BR-602	Run reconciliation invariants at query time and show the result beside the figures	MUST	BUILT
BR-603	Provide role-scoped dashboards for each persona in section 4	MUST	BUILT
BR-604	Filter on 24 dimensions including rail, family, severity, state, product, segment, region, FMR and STR status	MUST	BUILT
BR-605	Drill from any figure through to the individual transaction and its evidence trail	MUST	BUILT
BR-606	Show the rule-evaluation trace: why this fired, on what observation, under which config version	MUST	BUILT
BR-607	Visualise the counterparty network with hub identification	SHOULD	BUILT
BR-608	Trend every headline metric over daily, weekly and monthly buckets	MUST	BUILT
BR-609	Save, share and schedule views; distribute exports to named recipients. Scheduled exports now deliver: the <code>email</code> driver sends the artefact as an attachment through the recipient tenant's own configured SMTP relay (notification-service's <code>/internal/channels/send</code>) rather than only reporting itself unconfigured	SHOULD	BUILT
BR-610	Export to CSV with a watermark and a row ceiling, audited	MUST	BUILT
BR-611	Distinguish live traffic from demonstration data in every view	SHOULD	BUILT

11. Requirements — identity, access and privacy

BR-7xx. The largest concentration of unmet requirements, and the hardest blocker

to a bank IS sign-off.

ID	REQUIREMENT	PRIORITY	STATUS
BR-701	Enforce role-based access across modules and dashboards. Found and fixed this cycle: cp_common.rbac has always granted the <code>audit</code> module to six tenant-scoped roles (tenant_admin, risk_manager, principal_officer, supervisor, cro, rbi_inspector), and the console has always shown all six an "Audit" nav item — but <code>GET /audit</code> was gated <code>require_role("platform_admin")</code> only, so every one of those roles 403'd the moment they used it. The grant existed; the enforcement of it did not. Fixed: the endpoint now checks the caller's audit-module access dynamically (also recognising a BR-113 custom role granted the module), scoped to the caller's own tenant only — platform staff keep the unscoped, cross-tenant view. Verified end-to-end through the running console, not only by test, since this is exactly the kind of gap a unit test written against the same wrong assumption would not have caught. Update (BR-113 phase 2e): the module and dashboard grants are now each tenant's own role rows rather than a catalogue in code, and enforcement reads only those rows	MUST	BUILT
BR-702	Mask customer identifiers by default; unmasking requires capability plus a recorded justification	MUST	BUILT
BR-703	Audit every view of customer-level evidence, not only every change	MUST	BUILT
BR-704	No tenant may read another tenant's data under any role or query path	MUST	BUILT
BR-705	Maintain an immutable platform audit trail of every action, actor, role and outcome	MUST	BUILT
BR-706	Force password change at first login; enforce password complexity	MUST	BUILT
BR-707	Multi-factor authentication for all users	MUST	BUILT
BR-708	Federated sign-on against the bank's own IdP (SAML / OIDC), with group-to-role mapping	MUST	BUILT
BR-709	Session timeout, refresh tokens, revocation and concurrent-session control	MUST	BUILT
BR-710	Account lockout and credential-stuffing protection on authentication	MUST	BUILT
BR-711	Per-caller rate limiting at the platform edge	MUST	BUILT
BR-712	Encryption at rest with tenant-scoped key management; TLS in transit	MUST	PARTIAL
BR-713	Retention schedule and automated purge, aligned to fraud-record retention and DPDP minimisation (REG-05)	MUST	BUILT
BR-714	All payment data stored within India (REG-07)	MUST	PARTIAL
BR-715	Maker-checker on privileged configuration changes, not only on fraud declaration. Activating a rule or policy version now passes through <code>pending_activation</code> : a second, different person whose role holds the activation capability must confirm before it reaches live decisioning, and the proposer may not be the confirmer	SHOULD	BUILT
BR-716	A downloadable audit report, filterable by action — e.g. a role-management-only export for a compliance review or an RBI inspection request. <code>GET /audit/export</code> reuses BR-701/BR-705's own access rule and filters rather than standing up a parallel reporting path: platform staff export any tenant (or every tenant), everyone else their own only. Streams CSV with a sanitised filename — a filter value is never reflected into the response header unescaped, closing a header-injection surface before it could exist. A console control ("Role changes only" + Download CSV) sits on the existing Audit panel	SHOULD	BUILT

12. Requirements — model and detection governance

BR-8xx. FREE-AI expectations, applied to a rules engine today and to models when they arrive.

ID	REQUIREMENT	PRIORITY	STATUS
BR-801	Maintain an inventory of every detection version that has scored live traffic	MUST	BUILT
BR-802	Flag any configuration version scoring live traffic that is not currently approved	MUST	BUILT
BR-803	Monitor population drift (PSI, KS) against a reference window and band the result	MUST	BUILT
BR-804	Log every human override of a detection outcome with its rationale	MUST	BUILT
BR-805	Every alert must be explainable to a non-technical reviewer without reference to source code	MUST	BUILT
BR-806	Backtesting harness: replay a candidate configuration against history and compare outcomes	MUST	BUILT
BR-807	Champion/challenger evaluation before a configuration is promoted. Gated on the new <code>model</code> config kind: activation may not even be proposed without a recorded evaluation (metrics, method, comparison to the version it would replace)	SHOULD	BUILT
BR-808	Record model approval by the responsible committee before activation. Extends BR-104's board-attestation mechanism to the <code>model</code> kind, with a new Model Risk Management Committee approving body	SHOULD	BUILT

13. Requirements — platform operations

BR-9xx. What the vendor must be able to evidence under REG-06 and REG-08.

ID	REQUIREMENT	PRIORITY	STATUS
BR-901	Each service owns its data; no service may read another's tables	MUST	BUILT
BR-902	Run multiple replicas of every service behind a load balancer without inconsistent results	MUST	BUILT
BR-903	A failing component must not take down healthy ones	MUST	BUILT
BR-904	Client retries must not duplicate an action	MUST	BUILT
BR-905	Distinguish liveness from readiness so a dependency blip does not restart the fleet	MUST	BUILT
BR-906	Correlate a request across every service it touches	MUST	BUILT
BR-907	Metrics, tracing and log shipping to a central observability stack	MUST	PARTIAL
BR-908	Documented and tested backup, restore and disaster recovery, with stated RPO and RTO	MUST	PENDING
BR-909	Capacity and load testing evidence at each tenant's contracted peak rate	MUST	PENDING
BR-910	Right-to-audit support: evidence pack, control descriptions, sub-processor register (REG-06)	MUST	PENDING
BR-911	Documented exit plan with data return in a usable format and agreed deletion	MUST	PARTIAL

14. Non-functional requirements

Targets to be contracted per tenant. Those marked unvalidated have not been measured and must not be quoted commercially until they are.

ID	ATTRIBUTE	TARGET	STATUS
NFR-01	Detection latency	Under 5 seconds from receipt to alert at peak	UNVALIDATED
NFR-02	Ingestion throughput	Sustained peak TPS per tenant, contracted individually	UNVALIDATED
NFR-03	Dashboard response	95th percentile under 3 seconds on 12 months of data	UNVALIDATED
NFR-04	Availability	99.5% monthly for the console; 99.9% for ingestion	DESIGN SUPPORTS
NFR-05	Recovery	RPO 15 minutes, RTO 4 hours	PENDING
NFR-06	Data residency	All data in Indian regions (REG-07)	DEPLOYMENT-DEPENDENT
NFR-07	Retention	Fraud records for the statutory period; operational data minimised (REG-05)	PENDING
NFR-08	Auditability	Every figure reproducible as at any past date, against the config then in force	BUILT
NFR-09	Accessibility	WCAG 2.1 AA for the console	NOT ASSESSED
NFR-10	Browser support	Current Chrome, Edge, Firefox, Safari; no external CDN dependency (air-gapped deployments)	BUILT

15. Obligation traceability

Each regulatory obligation to the requirements that discharge it, and the honest state of each.

OBLIGATION	SOURCE	REQUIREMENTS	STATE
Board-approved fraud risk policy governs thresholds	REG-01	BR-103, BR-104, BR-105	MET — ACTIVATION RECORDS THE APPROVING BODY, DATE AND MINUTE REFERENCE

OBLIGATION	SOURCE	REQUIREMENTS	STATE
EWS framework with defined indicators	REG-01	BR-301, BR-307	MET
EWS operates on actual transaction data	REG-01	BR-201 – BR-208, BR-302	MET — RAILS, CBS EVENTS AND REFERENCE FEEDS
Red Flagged Account classification and review	REG-01	BR-401, BR-402	MET
Hearing before adverse classification	REG-02	BR-403, BR-404, BR-405	MET
Reasoned (speaking) order for a fraud finding	REG-02	BR-406, BR-412	MET
Fraud declaration under dual control	REG-01	BR-407	MET
FMR reporting within the prescribed window	REG-01	BR-501, BR-502, BR-503, BR-504	CLOCKS TRACKED; ARTEFACT ASSEMBLED, VALIDATED AND RETAINED — PRESCRIBED FORMAT PENDING OD-04
STR reporting to FIU-IND	REG-03	BR-505	ASSEMBLED AND RETAINED; PRESCRIBED FORMAT PENDING OD-04
Staff accountability examination	REG-01	BR-414	MET
Board and ACB oversight reporting	REG-01	BR-507, BR-603	MET — DASHBOARDS AND SCHEDULED PACK WITH RECORDED DELIVERY
Model governance, explainability, human oversight	REG-04	BR-801 – BR-805	MET FOR A RULES ENGINE
Model validation before deployment	REG-04	BR-806, BR-807, BR-808	BACKTESTING BUILT; CHAMPION/CHALLENGER AND COMMITTEE APPROVAL PENDING
Access control, MFA, privileged access management	REG-08	BR-701, BR-707 – BR-710	MET — RBAC, MFA, OIDC/SAML, SESSIONS, LOCKOUT
Purpose limitation and data minimisation	REG-05	BR-702, BR-703, BR-713	MET — MASKING, RETENTION FLOORS, AUTOMATED PURGE
Payment data localisation	REG-07	BR-714	DEPLOYMENT-DEPENDENT

OBLIGATION	SOURCE	REQUIREMENTS	STATE
Service-provider audit, exit and concentration risk	REG-06	BR-107, BR-910, BR-911	EXIT EXPORT RETURNS THE FULL FRAUD RECORD AND DECLARES ITS OWN COMPLETENESS; RIGHT-TO-AUDIT PACK PENDING
Change management and audit logging	REG-08	BR-105, BR-705, BR-409	MET

16. Assumptions, constraints and exclusions

Assumptions

- Each tenant can expose transaction data by API or file within minutes of settlement
- Each tenant's board approves its own thresholds; the vendor supplies defaults, never advice
- Banks will federate identity from an existing IdP rather than manage users in the platform long-term
- Reference data (sanctions, CERSAI, CBS extracts) can be licensed or supplied by the tenant

Constraints

- Payment data must remain in India, constraining hosting and any sub-processor
- Some tenants require air-gapped or private-cloud deployment; no runtime dependency on an external CDN
- Money is integer paise throughout; no floating-point representation is permitted anywhere in the stack
- Reported figures must reconcile exactly, which rules out eventually-consistent read models for reported metrics

Exclusions

- The platform is not a system of record for customers, accounts or the general ledger
- It does not authorise, block or reverse payments
- It does not provide legal advice on classification; it enforces the process around the decision

17. Release plan

Sequenced by what blocks a signed contract, not by engineering convenience.

RELEASE	THEME	CONTENTS	EXIT CRITERION	STATUS
R1	Bankable	BR-707 – BR-710 (MFA, SSO, sessions, logout); BR-413 (notifications); BR-712, BR-713 (encryption, retention)	A bank's IS and security review can be passed	NEARLY MET MFA, SSO (OIDC + SAML), sessions, logout, notifications and retention are built, and the secrets a database reader could abuse are sealed. The one remaining item is the infrastructure half of BR-712 : full-disk or tablespace encryption, which the application cannot provide.
R2	Filable	BR-504 – BR-506 (FMR and STR artefacts); BR-414 (staff accountability); BR-507 (scheduled board pack)	A full fraud can be taken from signal to submitted return inside the platform	NOT MET Staff accountability, artefact retention and board-pack production and delivery are all built. It is not met for one reason: BR-504 and BR-505 require the <i>prescribed</i> RBI and FIU-IND formats, and the platform declares both bindings <code>not_bound</code> pending OD-04 . That is a compliance decision, not engineering work.
R3	Complete detection	BR-209 – BR-212 (files, backfill, CBS, reference feeds); BR-310 (graph typologies); BR-309 (streaming latency)	EWS coverage no longer qualified by missing feeds	NEARLY MET File intake now covers ISO 20022 as well as CSV, and backfill and replay, graph typologies, CBS events and scheduled reference feeds are all built. Only BR-309 remains - sub-second detection at contracted peak is asserted rather than measured, and closing it needs the load-test evidence of BR-909 .

RELEASE	THEME	CONTENTS	EXIT CRITERION	STATUS
R4	Operable at scale	BR-907 – BR-909 (observability, DR, load testing); BR-910, BR-911 (audit and exit); NFR validation	NFR targets measured and contractable	PARTLY MET Metrics, request correlation and pipeline-freshness gauges are in place. Tracing and log shipping, DR (BR-908), load-test evidence (BR-909) and the right-to-audit pack (BR-910) are not.
R5	Commercial	BR-109, BR-110 (self-service, metering); BR-806 – BR-808 (backtesting, champion/challenger)	Onboarding a tenant needs no vendor engineering	NEARLY MET Backtesting (BR-806) and per-tenant usage metering (BR-110) are built. A tenant administrator can now configure their own identity providers from the console — create, edit and remove OIDC/SAML sources, with role-mapping validated against the tenant's own assignable roles — closing the specific gap that previously forced vendor engineering for IdP setup. The console can also now create and activate a tenant's FRM policy version directly — <code>ConfigCreate.kind</code> was refusing <code>policy</code> at the schema; that is fixed, and BR-104 's threshold override and the Principal Officer designation (BR-504/505) are reachable end-to-end rather than only by writing to the database. Self-service tenant onboarding (BR-109) is now built — a prospective bank provisions its own sandbox with no platform_admin action at all, satisfying this gate's own wording for the onboarding step itself. Growing an existing tenant's own user base is also self-service and always has been: <code>POST /tenants/{id}/users</code> is gated on the dynamic <code>can_admin_tenant</code> capability, which tenant_admin (or any custom role a bank has granted it to) already carries — no platform_admin action is or was required for this step; an earlier version of this note said otherwise and was wrong. What was a real, separate gap — the invited user received no email, only a one-time password shown on the inviting admin's own screen to relay by hand — is now closed: invitation sends the credential directly through the tenant's own configured email channel (the same direct-send path BR-609 's scheduled report export uses) when one exists, falling back to the on-screen password, honestly labelled, only when it does not.

18. What still blocks a commercial release

The honest list, ordered by what stops a signature soonest. Everything here is a MUST that a bank, its IS reviewer or its regulator asks about directly.

REF	GAP	WHY IT BLOCKS	GATE
BR-504/505	FMR and STR artefacts in the <i>prescribed</i> submission format	The single blocker on R2. The platform assembles, validates, hashes and retains the return and refuses to generate one with gaps, but the format bindings are declared <code>not_bound</code> . A named officer can submit from the pack; the platform cannot claim the return is in RBI's or FIU-IND's own format until OD-04 is decided. This needs the published schemas, not engineering. Separately: a defect that left the STR path permanently unfileable — the Principal Officer field had no source anywhere in the platform, so every STR was refused regardless of format — is fixed and verified end-to-end against a live case, and a tenant admin can now set that field themselves through the console (below), with the designation gated by the same board-attestation mechanism as every other policy fact.	R2
BR-712	Full-disk / tablespace encryption	Application-layer sealing of MFA seeds, IdP secrets and feed credentials is done. Encrypting the volume itself protects a stolen disk or a discarded backup and is a deployment control — Postgres TDE, LUKS or the cloud provider's volume encryption. An IS review asks for both.	R1
BR-909	Capacity evidence beyond a single worker	Detection latency is now measured — 200 tps per worker at p99 2.65 s, with the run refusing to call itself sustained if the backlog climbs. What is still unevidenced is multi-worker scaling and the managed-database deployment. The machine-to-machine credential that previously blocked driving the intake path under load is now built (BR-201), so this is a matter of running the test at scale rather than a missing capability.	R4
BR-908	Tested backup, restore and disaster recovery with stated RPO/RTO	Contractual. An untested restore is an assumption, and the outsourcing directions expect the numbers to be evidenced.	R4
BR-910	Right-to-audit evidence pack and sub-processor register	RBI's outsourcing directions give the regulated entity and the RBI a right to audit the service provider. It has to be answerable on request.	R4
BR-907	Distributed tracing and log shipping	Metrics, structured logs and a request id that crosses every service are in place. Nothing ships them to a central stack, so an incident is investigated by reading files on each host.	R4
BR-211 (residual)	Invoice, geolocation and trade-finance records	Five indicators — SME-03, CHN-02 and TBM-01/02/03 — still cannot be measured. They are reported as unmeasurable with the reason rather than scored, which is correct, but it is EWS coverage a bank is paying for and not receiving.	R3

19. Open decisions

Items requiring a business decision before the corresponding engineering can be

specified.

REF	DECISION	WHY IT MATTERS	OWNER
OD-01	Deployment model: shared multi-tenant, dedicated schema, or single-tenant install per bank	Larger banks may refuse shared infrastructure; changes cost model and DR design	Commercial
OD-02	Whether case management becomes a separately deployed service	Correct bounded context, but requires event sync that trades exact reconciliation for eventual consistency	Product + Engineering
OD-03	Whether to sit in the authorisation path for interdiction — decided: yes , per-tenant and per-rail. Built as Lane A in shadow mode. The <i>how</i> of graduating to enforcement is now built (BR-316): a per-rail graduation record, gated the same way a board-approved policy or a promoted model is. What remains open here is narrower still — which tenant is commercially first to actually graduate a rail, now that the mechanism exists to do it	Settled the latency budget (50–150 ms by rail), the availability class and the liability profile. Competitive necessity: Clari5, Signzy and Servosys all answer in the payment window	Commercial — open
OD-04	Which FMR and STR submission formats to target first	Formats differ by entity type and channel; determines R2 scope	Compliance
OD-05	Reference data: licensed centrally by the platform, or supplied per tenant	Sanctions and CERSAI licensing cost and liability	Commercial
OD-06	Whether ML-based detection is in roadmap scope — decided: yes , committed as the four-phase programme in AI/ML roadmap (device & behavioural biometrics; transaction velocity & anomaly models; GNN fraud-ring detection & federated learning; explainable-AI dashboards & regulator-ready reporting) — the first two phases are now Built and genuinely scoring traffic (VEL-04, LAY-05), not just gated ahead of a model existing. What remains open: Phase 4 has no committed delivery date. The governance floor BR-807/BR-808 (champion/challenger evaluation, committee approval before activation) gate a new model config kind, refusing to even propose activation without both on record	Triggers the full FREE-AI model-governance obligation set. BR-801–806 (inventory, drift monitoring, human-override logging, explainability, backtesting) are already built against the rules engine and extend to every phase's models; BR-807/808 are built as the activation gate itself and apply the moment a model version is proposed	Executive — decided, timeline open
OD-07	Federated learning's data-sharing basis (Phase 3): aggregating model updates within one tenant's own data only, or across tenants/banks — decided: not within one tenant . Federated learning across a single tenant's own data is not federated learning at all — it is ordinary centralised training with an extra network hop, since there is only one data holder. The whole premise requires multiple independent holders, which for this platform means multiple banks. That is a materially different data-sharing posture from anything the platform does today (AD-03: schema-per-service, no cross-tenant queries, enforced at the database role), and the platform will not build it speculatively: it is not commercially triggered by any engagement in front of it. GNN fraud-ring detection does not wait on this — it proceeds within one tenant's own account graph, which needs no new data-sharing basis at all, and is no longer coupled to Phase 3 in the roadmap	Settles that Phase 3 is buildable now for GNN alone. Cross-bank fraud-signal sharing has a regulatory precedent this platform already integrates — RBI's own Central Fraud Registry (BR-509) — but CFR is RBI-operated reference data the platform <i>screens against</i> , not a federation the platform would itself run. A future consortium engagement that wants genuine federated training gets its own OD when it exists, with its own consent basis named by the banks actually party to it	Executive — decided

20. AI/ML roadmap

Referenced from [OD-06](#) as the committed scope; Phase 4 has no committed delivery date. Sequenced by dependency, not by ambition — each phase produces the input the next one needs, which is why Phases 2 and 3 are both Built in order: Phase 3 reuses Phase 2's scoring pipeline and the account graph the platform already exposed, needing only a GNN encoder on top, not a new architecture. Federated learning was originally bundled into Phase 3; [OD-07](#) has since split it out as Phase 3b, deferred and commercially triggered rather than engineering-scheduled — see its own row below for why.

PHASE	THEME	CONTENTS	GOVERNANCE & DEPENDENCIES	STATUS
Phase 1	Device & behavioural biometrics	Extend the channel (CHN) signal family with device-posture and behavioural-biometric features — typing cadence, touch pressure, session/gesture patterns — alongside the device id already captured per transaction.	Additive signal ingestion into the existing rules engine, not a scored model, so the BR-801–808 model-governance gate does not yet apply. Capture and matching itself is not built here: it is VideoPD's and the Human Fraud Detection Framework's domain (liveness, face-match, voice-biometric, persona signals). Fraud360 consumes their signal output as a new feature class; it does not duplicate biometric capture engineering.	PENDING

PHASE	THEME	CONTENTS	GOVERNANCE & DEPENDENCIES	STATUS
Phase 2	Transaction velocity & anomaly-detection models	The first genuine scored-model phase, now live: adds a learned velocity/anomaly indicator (VEL-04) alongside the threshold-based VEL family, over the same transaction stream. Scoring runtime built per AD-14 — runs in-process inside the existing detection worker (analytics-service, Python/FastAPI), not a new service: an IsolationForest over five tabular features already computed for the rules engine (no second feature pipeline), calibrated against the training set's own score distribution rather than a fixed formula. See <code>services/analytics_service/app/detection/model_scoring.py</code> and <code>scripts/train_velocity_anomaly_model.py</code>.	BR-807/808 gate activation — cannot go live without a champion/challenger evaluation on record and committee approval per config version — and a third gate now sits beside them: <code>model_artifact</code> (format, object-storage URI, SHA-256), verified before the trained binary is even loaded, refusing a mutated or truncated file rather than silently scoring with something nobody approved. BR-801–806 apply from the first scored alert. First working fit, not a validated one — trained against whatever history a tenant already has; detection quality against real fraud outcomes is unmeasured until BR-806's backtesting harness runs against live traffic, a separate, later exercise this phase does not claim to have done.	BUILT
Phase 3	GNN-based fraud-ring detection	Built — see HLD §16 for the architecture. A 2-layer GraphSAGE (inductive: scores an account it has never seen at training time, which a constantly-changing account graph needs) produces a node embedding per account; the same AD-14/AD-15 scoring pipeline Phase 2 already built (calibrated anomaly score, not a new formula) scores those embeddings for anomalousness. New indicator LAY-05 (fraud-ring membership), extending the layering/mule family — not VEL, since this is topology, not velocity. Training input is the account graph <code>GET /analytics/{tid}/graph</code> already exposes for visualisation, extended to the tenant's whole graph rather than one case's neighbourhood (<code>services/analytics_service/app/detection/graph_model.py</code>), within one tenant's own data per OD-07's resolution. No new data-sharing basis was needed for this. Unlike VEL-04, LAY-05 is not scored inline per transaction — a GraphSAGE forward pass over the whole graph runs on its own schedule (<code>scripts/refresh_ring_scores.py</code> , the same shape as <code>run_subscriptions.py</code> / <code>run_retention.py</code>), writing <code>analytics.account_ring_score</code> , which the detection worker only reads.	Same BR-807/808 activation gate, plus the explainability standard BR-801–806 already hold the rules engine to: a fraud-ring flag must stay traceable to why it fired, same as every alert's rule-evaluation trace today. The prerequisite this phase exposed is fixed, not merely noted: <code>/internal/model/{tid}/{name}</code> and <code>rules.active_model(tenant_id, name)</code> are now keyed by the config's own <code>name</code> , not the tenant alone — the config data model already supported two same-kind, differently-named active versions (<code>ConfigRepository.activate()</code> archives by tenant+kind+name); only the query layer needed to ask for the right one, and now does. <code>velocity-anomaly</code> (VEL-04) and <code>graph-ring-score</code> (LAY-05) are active independently, each reachable only by its own name. First working fit, not a validated one — same caveat as Phase 2: trained unsupervised (no ring labels exist to train against) against whatever history a tenant already has; detection quality against real fraud-ring outcomes is unmeasured until BR-806's backtesting harness runs against live traffic.	BUILT
Phase 3b	Federated learning DEFERRED	Decoupled from Phase 3 by OD-07: aggregating model updates across tenants/banks is a materially different data-sharing posture than anything this platform does today, and is not commercially triggered by any engagement in front of it. Not on this roadmap's critical path — taken up only if and when a specific multi-bank engagement creates both the demand and the consent basis for it.	N/A until OD-07 is revisited by a real engagement.	NOT SCHEDULED
Phase 4	Explainable-AI dashboards & regulator-ready reporting	Extends the Model Risk dashboard's model-inventory and override-log endpoints (§12, model and detection governance) into a regulator-facing explainability report, delivered through the scheduled-distribution machinery already built for board packs (BR-507, <code>scripts/run_subscriptions.py</code>).	Reporting on governance data Phases 2 and 3 must already be producing — there is nothing to explain or report on until a model exists. Not independently startable.	PENDING

Status summary. 106 business requirements: 91 built, 7 partial, 8 pending. Statuses reflect verified behaviour in the current build — every item marked Built is covered by an automated test in a suite of 809. Partial always means the requirement is not yet met as written; the reason is stated in section 17b.

This document describes a product under development. It is not legal or regulatory advice; each regulated entity remains responsible for its own compliance and for the threshold values it approves.

